

AI Incident Response Checklist

A practical checklist for triaging, containing, investigating, remediating, and closing incidents involving AI tools, models, agents, data exposure, unsafe outputs, or unauthorized AI use.

Purpose

Use this checklist during an active AI-related incident to make sure the response team covers the basics without missing the ugly details: what happened, what data or outputs were affected, how to contain harm, which stakeholders must be notified, and how to close the incident with evidence and lessons learned.

Document Type	Operational incident checklist	Version	1.0
Prepared For	{{COMPANY_NAME}}	Owner	{{AI_GOVERNANCE_LEAD / IR LEAD}}
Review Cycle	At least annually and after major incidents	Related Artifacts	AI Acceptable Use Policy / AI Use Case Registry
Primary Users	Security, IT, privacy, legal, business owners, incident managers	Status	Draft / Approved / In Use

How to use this checklist

- Use it during a live incident or tabletop, not as post-incident fan fiction.
- If a step is not applicable, mark why; if it is incomplete, name the owner and due date.
- Log material facts, decisions, and evidence references while the incident is happening.
- Any confirmed incident should also update the AI Use Case Registry, shadow AI log, and relevant risk or vendor records where applicable.

1. Identify and validate the incident

Confirm that the event is real enough to open an incident and describe what makes it AI-related.

Check	Required step or confirmation	What should be covered	Notes / evidence
☐	Capture the initial report and time of discovery.	Record who reported it, when it was detected, how it was observed, and whether this is active, suspected, or historical.	
☐	Describe the AI-related event clearly.	Examples include prompt leakage, unauthorized AI use, harmful output, model misuse, agent overreach, vendor outage, data exposure, or policy breach.	
☐	Identify the impacted tool, model, workflow, or vendor.	List the AI system, feature, API, embedded product, or shadow AI tool involved.	
☐	Confirm whether the issue meets incident criteria.	Determine whether the event requires formal response versus routine bug handling, quality tuning, or policy coaching.	

2. Classify severity and activate the response team

Decide how serious the issue is and who needs to be pulled in before the incident grows legs.

Check	Required step or confirmation	What should be covered	Notes / evidence
☐	Assign a provisional severity or priority.	Use your incident scale based on business impact, data sensitivity, external exposure, operational disruption, or safety implications.	
☐	Identify incident lead and core responders.	Name the coordinator plus security, IT, privacy, legal, vendor management, or business owners as needed.	
☐	Decide whether a war room or formal incident bridge is required.	Use this for high-severity cases, external exposure, or time-sensitive containment decisions.	
☐	Record the first executive notification trigger if needed.	Note whether leadership must be informed immediately based on severity, customer impact, or legal risk.	

3. Contain the immediate risk

The first job is to stop further harm without casually smashing evidence or business continuity in the process.

Check	Required step or confirmation	What should be covered	Notes / evidence
☐	Decide whether to disable or restrict the AI capability.	Pause accounts, APIs, plugins, agents, automations, or routing where continued use could worsen harm.	
☐	Block unsafe data flows or integrations.	Suspend file uploads, connectors, token access, shared mailboxes, knowledge sources, or system-to-system actions if necessary.	
☐	Preserve business-safe fallback options.	Define manual workarounds, human review steps, or service degradations so the business can keep breathing.	
☐	Document containment decisions and approval.	Capture who authorized containment, when it happened, and what systems or users were affected.	

Containment note

If the incident involves autonomous actions, outbound integrations, or customer-facing responses, prioritize the fastest safe kill switch available. A graceful shutdown is lovely. A preventable blast radius is not.

4. Preserve evidence and establish facts

AI incidents get muddy fast. Evidence discipline matters because memory is a terrible log source.

Check	Required step or confirmation	What should be covered	Notes / evidence
☐	Preserve relevant logs, prompts, outputs, tickets, and screenshots.	Capture records from AI platforms, identity systems, applications, proxies, chat histories, audits, or SIEM sources.	
☐	Identify the data and users affected.	Document what information was entered, exposed, processed, or output, and which users, customers, or employees were impacted.	
☐	Record the incident timeline as facts emerge.	Track first observed time, last known good state, containment milestones, and key decisions.	
☐	Note uncertainty and known gaps honestly.	Mark what is confirmed, what is suspected, and what still needs verification.	

5. Assess impact, exposure, and downstream harm

Move beyond the technical event and assess what actually matters to the organization and affected people.

Check	Required step or confirmation	What should be covered	Notes / evidence
☐	Determine confidentiality, integrity, or availability impact.	Assess whether data leaked, outputs were manipulated, systems acted incorrectly, or services became unavailable.	
☐	Determine whether the incident influenced decisions or actions.	Check whether people or systems acted on harmful outputs, recommendations, classifications, or generated content.	
☐	Identify customer, employee, regulatory, or reputational impact.	Call out public exposure, HR issues, legal exposure, financial consequences, or trust damage.	
☐	Decide whether the issue involves a high-consequence context.	Flag incidents affecting HR, finance, healthcare, safety, legal, or customer-facing decision processes.	

6. Escalate and communicate

Get the right people involved before communication becomes improvisational theater.

Check	Required step or confirmation	What should be covered	Notes / evidence
☐	Engage privacy, legal, compliance, and executive stakeholders where triggers apply.	Use established criteria for personal data, contractual exposure, public communication risk, or regulated obligations.	
☐	Assess whether vendor escalation is required.	Notify the AI vendor or SaaS provider when the incident involves their platform, model, outage, or shared responsibility.	
☐	Prepare internal communication guidance.	Provide a controlled message for help desk, managers, or employees if user action or temporary restrictions are needed.	
☐	Evaluate external notification obligations.	Consider customers, partners, insurers, regulators, or law enforcement if the facts and thresholds support it.	

Notification note

Do not guess on breach, notice, or regulatory thresholds in the heat of the incident. Escalate to privacy and legal early when personal data, customer harm, or contractual commitments may be involved.

7. Eradicate the root cause or unsafe condition

Containment buys time; eradication is where you remove the cause, not just the symptom wearing a fake moustache.

Check	Required step or confirmation	What should be covered	Notes / evidence
☐	Identify the likely root cause or failure mode.	Examples include weak access control, bad configuration, risky vendor behavior, shadow AI use, poor prompts, absent guardrails, or broken oversight.	
☐	Implement corrective technical or process changes.	Rotate keys, disable plugins, patch workflows, tighten access, add filtering, revise prompts, or change integrations as needed.	
☐	Remove or remediate unauthorized AI usage.	Address shadow AI tools, unapproved accounts, or workflows that bypassed governance requirements.	
☐	Confirm whether additional validation is needed before re-enabling service.	Define what evidence, testing, or approvals must exist before rollback or go-live.	

8. Recover safely and monitor

Recovery is not just turning it back on and hoping the ghost has left the machine.

Check	Required step or confirmation	What should be covered	Notes / evidence
☐	Approve the recovery plan and scope.	Document what will be restored, for whom, under what restrictions, and with whose approval.	
☐	Test the restored capability or workaround.	Check whether controls now work as intended and whether outputs, access, and data flows behave safely.	
☐	Increase monitoring for recurrence or residual risk.	Add focused logging, alerting, sample review, business-owner checks, or vendor follow-up during the watch period.	
☐	Document business acceptance of residual risk if any remains.	Record any temporary exception, monitoring period, or compensating control that supports recovery.	

9. Capture lessons learned and governance updates

A closed incident that teaches nothing is basically tuition without the degree.

Check	Required step or confirmation	What should be covered	Notes / evidence
☐	Hold a short lessons-learned review.	Identify what detection, policy, training, vendor control, or architecture weakness allowed the incident to happen or linger.	
☐	Update policies, standards, or procedures where needed.	Adjust acceptable use rules, incident playbooks, procurement checks, data handling rules, or review gates.	
☐	Feed findings into training and awareness.	Decide what employees, admins, developers, or managers need to be told or retrained on.	
☐	Update related risk, vendor, or use-case records.	Tie the incident to the right use case, vendor file, and governance records so the program actually learns.	

10. Closure, lessons learned, and sign-off

Use this final checkpoint before the incident is formally closed, logged, and handed back into business-as-usual governance.

Check	Required step or confirmation	What should be covered	Notes / evidence
☐	The final incident summary is complete.	The record includes timeline, root cause hypothesis or finding, impact summary, actions taken, and open residual risks.	
☐	Required notifications and communications have been completed or deferred with approval.	Capture internal notices, customer notices, regulator decisions, vendor notices, or law enforcement engagement where relevant.	
☐	Corrective actions and owners have been assigned.	Document what changes are required to policy, training, technical controls, vendors, or monitoring, and who owns them.	
☐	Related governance records have been updated.	Update the AI Use Case Registry, shadow AI log, vendor file, incident tracker, and control library as needed.	

Check	Required step or confirmation	What should be covered	Notes / evidence
[]	Closure approval has been recorded.	Mark whether the incident is closed, monitoring-only, or remains open due to pending remediation.	

Incident ID	{{INCIDENT_ID}}	Severity	{{SEV-1 / SEV-2 / SEV-3}}
Incident Lead	{{NAME}}	Closure Date	{{DATE}}
Approved by	{{SECURITY / BUSINESS / PRIVACY LEAD}}	Status	{{CLOSED / MONITORING / OPEN}}
Next Review Date	{{DATE}}	Reference Links	{{CASE / TICKET / REGISTRY ENTRY}}